

Cisco Secure Workload — DORA Compliance Mapping

Customer Compliance Report

Cisco Secure Workload — Compliance Mapping Series

Table of Contents

Cisco Secure Workload — DORA Compliance Mapping

Customer: [Customer Name] **Prepared:** [Month Year] **Standard:** Regulation (EU) 2022/2554 — Digital Operational Resilience Act (DORA) **Effective:** 17 January 2025 **Document type:** Customer-facing compliance mapping

How to read this report

This is a *control mapping*, not a certification. For each DORA pillar relevant to ICT operational risk, the report identifies how Cisco Secure Workload (CSW) capabilities can be used to produce evidence of the underlying control, what that evidence looks like in practice, and where complementary controls or governance work remain the responsibility of the financial entity.

Three pages to anchor on:

1. **Executive Summary** — what DORA expects, where CSW fits, where it does not.
2. **Compliance Posture Summary** — the at-a-glance pillar-by-pillar table. Replace the “Status” column with your own scope before sharing externally.
3. **Mapping Table** — Article-by-Article view linking DORA requirements to specific CSW capabilities and the artefact that demonstrates each.

For implementation steps, sample policies, and the auditor response playbook, see the companion [Technical Runbook](#).

How to read the coverage words

Full Coverage on the older reports means Secure Workload can produce that row's artifact. It does not mean the control is met.

Partial Coverage means file that export next to another control.

Evidence Required means Secure Workload has no record. The customer files the contract, the analysis, or the HR or physical-security evidence.

Direct, Supporting, and Out of scope on the newer reports are the same idea in different words. Direct is still evidence, not a pass.

1. Executive Summary

DORA establishes harmonised ICT operational resilience requirements across the EU financial sector. It applies from **17 January 2025** to financial entities (banks, payment institutions, investment firms, CCPs, insurers, crypto-asset and crowdfunding service providers) and imposes oversight obligations on critical ICT third-party providers (CTPPs).

Where CSW is most relevant. CSW provides workload-resident telemetry and segmentation that directly supports:

- **Pillar 1 — ICT Risk Management:** continuous asset inventory (Art. 8), segmentation enforcement (Art. 9), behavioural detection (Art. 10), and forensic data for response and learning (Arts. 11, 13).
- **Pillar 2 — Incident Management & Reporting:** time-anchored process and flow data supporting the Article 19 reporting cadence (initial / 72-hour / 1-month).
- **Pillar 3 — Digital Operational Resilience Testing:** vulnerability inventory and reachability evidence for Article 25 baseline tests; workload-level reconstruction for Article 26 TLPT.

Where CSW supports but does not solve. Pillar 4 (ICT third-party risk) is largely contractual; CSW provides the technical companion view — *what is my IBF actually talking to* — that lets the Register of Information be reconciled against observed behaviour. Pillar 5 (information sharing) and the governance obligations under Article 5 remain the responsibility of the management body.

2. Compliance Posture Summary

Replace the *Status* column with the customer’s own scope and deployment stage before sharing externally. The default reflects a mid-stage CSW deployment with most IBFs labelled and at least one IBF in enforced segmentation.

DORA Pillar	DORA Articles	CSW Coverage	Status
1. ICT Risk Management — Inventory	Art. 8	Continuous workload inventory + ADM dependency graph	Fully addressed
1. ICT Risk Management — Protection	Art. 9	Per-IBF segmentation, simulation → enforce workflow	Fully addressed (with policy authoring effort)
1. ICT Risk	Art. 10	Behavioural rules,	Fully addressed

DORA Pillar	DORA Articles	CSW Coverage	Status
Management — Detection		conversation-graph anomaly, SIEM forwarding	
1. ICT Risk Management — Response	Art. 11	Quarantine policy, forensic export bundle	Fully addressed
1. ICT Risk Management — Learning	Art. 13	Quarterly metrics pack	Supports (process is customer-owned)
2. Incident Management	Arts. 17–19	6-artefact dossier supporting 4h / 72h / 1mo cadence	Fully addressed (technical evidence)
3. Resilience Testing — Baseline	Art. 25	CVE dashboard + reachability queries	Fully addressed
3. Resilience Testing — TLPT	Art. 26	Red-team reconstruction + segmentation gap analysis	Fully addressed
4. Third-Party Risk — Technical view	Arts. 28(3), 28(4), 30(2)(c)	Egress observation + Register reconciliation	Supports (contractual flow is customer-owned)
4. Third-Party Risk — CTPP internal posture	Arts. 31–44	n/a (out of CSW scope unless CTPP runs CSW)	Out of scope
5. Information Sharing	Art. 45	Provides IOCs / behavioural signatures as input	Supports
Governance	Art. 5	Provides evidence to management body	Supports

3. Mapping Table — DORA Article → CSW Capability → Evidence Artefact

Article	Requirement (summary)	CSW capability	Evidence artefact
Art. 5	Management body accountability	Quarterly evidence pack feeds the management body	Quarterly DORA pack (PDF/CSV)
Art. 6	ICT risk management framework	Centralised inventory, policy and detection state	CSW dashboard exports

Article	Requirement (summary)	CSW capability	Evidence artefact
Art. 8(1)	Inventory of ICT assets	Continuous sensor-based inventory	inventory.csv per IBF
Art. 8(4)	Identify IBF-supporting assets	IBF labels + Scopes	Per-IBF scope export
Art. 8(6)	Update on every significant change	Daily snapshot + weekly delta	Drift report
Art. 9(2)(a)	Segregation of ICT systems	Per-IBF segmentation workspace	Workspace export (policy + clusters)
Art. 9(2)(b)	Identify unauthorised activity	ADM drift + flow anomalies	Drift detection report
Art. 9(4)(g)	Continuous review of segmentation	Quarterly policy diff	Diff report
Art. 10	Detection of anomalies	Behavioural rules + SIEM forwarding	Rule catalogue + SIEM config
Art. 11(2)	BCP, containment, recovery	Quarantine policy + forensic export	Quarantine evidence + export
Art. 13	Learning loop	Quarterly metrics pack	Metrics PDF
Art. 17	Incident management process	Forensic timeline reconstruction	Incident timeline export
Art. 18	Incident classification	IBF labels inform classification	Incident dossier with IBF context
Art. 19	Reporting deadlines (4h/72h/1mo)	6-artefact dossier	Time-stamped evidence bundle
Art. 24	Testing programme	Vulnerability + reachability evidence	Test catalogue with results
Art. 25(1)	Baseline tests	CVE dashboard + scenario reachability	Per-IBF test reports
Art. 26	TLPT (every 3 years for significant entities)	Red-team activity reconstruction	TLPT engagement reconstruction package
Art. 28(3)	Register of Information	Egress reconciliation feed	Register-vs-observed delta report
Art. 28(4)	Third-party risk monitoring	Continuous outbound flow monitoring	Egress trend report
Art. 30(2)(c)	Right to monitor third party	Technical evidence supporting contractual right	Per-CTPP egress dossier

4. Out-of-Scope and Complementary Controls

The following DORA areas are intentionally not addressed by CSW. They are listed here so the customer's compliance programme can confirm coverage from other tools or processes:

- **Article 5 governance and management-body sign-off** — process and documentation outside CSW.
 - **Articles 28(7)–30 contractual provisions with CTPPs** — legal function, supported by CSW egress evidence.
 - **Articles 31–44 ESA oversight of CTPPs** — competent-authority process; CSW does not interact with ESAs.
 - **Article 45 information-sharing arrangements** — sectoral agreements; CSW telemetry can be an *input*, not the arrangement itself.
 - **Identity, authentication and IAM controls under Articles 9(4)(c) and 9(4)(d)** — addressed by Cisco Duo, ISE, and the customer's IAM stack; CSW segmentation is identity-aware where labels carry identity context but is not an IAM solution.
-

5. Suggested Next Steps

1. Confirm the management-body-approved IBF list and its CSW label mapping.
 2. Pick one IBF to take through the full simulation → enforce cycle and produce a worked example of the §3 evidence artefacts.
 3. Schedule the quarterly DORA evidence pack so it precedes the management body's risk review meeting (Art. 5(2)).
 4. For significant entities, align the CSW evidence model with the TLPT cycle scheduled by your competent authority under Art. 26.
 5. Engage the Cisco account team for a scoping discussion if any of the *Status* column entries above need adjustment for the customer's actual deployment stage.
-

6. Disclaimer

This document describes how Cisco Secure Workload product capabilities can support a DORA programme. It is **not** legal, regulatory, or audit advice. DORA applicability, classification of “important business functions,” classification of incidents under the RTS, TLPT scoping, and contractual obligations under Articles 28–30 are the responsibility of the financial entity's management body and its qualified legal, compliance, and audit professionals, working with the relevant competent and lead authorities. Always validate against the latest published Regulatory Technical Standards (RTS) and Implementing Technical Standards (ITS), and any guidance issued by your lead overseer.

For questions or to validate how this mapping applies to your specific environment, contact your **Cisco account team**.